

ANNEXURE B: ROLE-BASED ACCESS CONTROL (RBAC) MATRIX

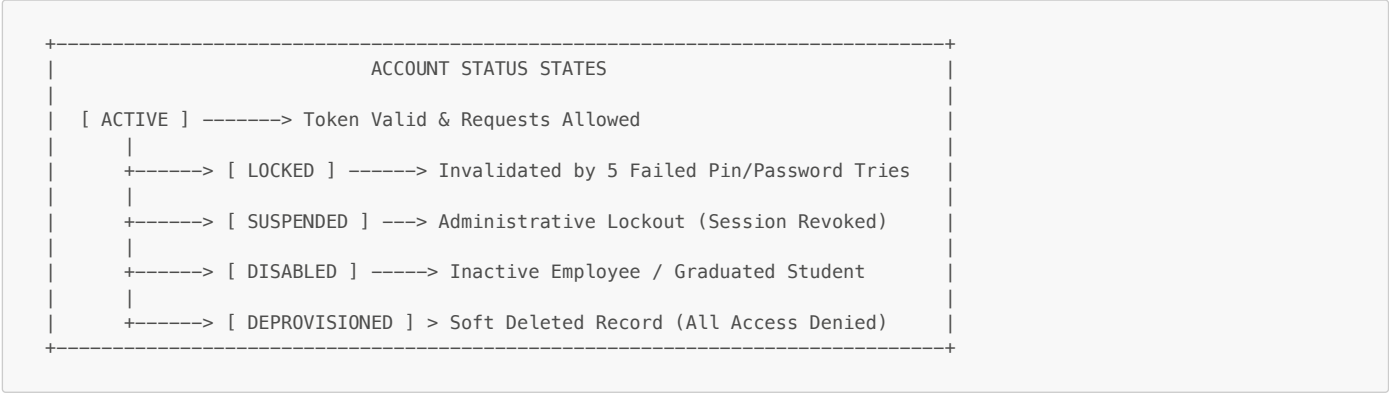
System Name: Educational Institution Gate Monitoring & Access Control System
Document Version: 1.0.0
Date: August 17, 2026
Classification: Confidential - Security Policy Reference

1. System Roles & Hierarchical Definitions

Role	Role Level	Scope of Authority	Description
sysadmin	Level 0 (Highest)	System-Wide	Platform system administrator with unmitigated administrative access, system maintenance capabilities, schema trigger configuration, and user provision/deprovision controls.
admin	Level 1	Institutional	Administrative staff managing student records, issuing global announcements, generating analytical reports, and executing secondary gate pass approvals.
supervisor	Level 2	Gate Cluster / Hostel	Gate supervisors overseeing multiple assigned gates, reviewing scan logs, resolving alerts, and authorizing manual scan corrections.
operator	Level 3	Assigned Gate	Physical gate security operators conducting barcode/QR scans, verifying digital IDs, and recording entry/exit events.
warden	Level 3	Hostel Block	Hostel wardens managing student room allocations, monitoring hostel curfews, and processing hostel-specific exit permissions.
student	Level 4	Self Only	Enrolled students viewing personal profile, generating dynamic identity QR codes, and submitting gate pass applications.
parent	Level 4	Dependent Children	Linked parents/guardians reviewing ward activity, tracking gate crossings, and providing primary pass authorization.

2. Account Status State Machine

Every user record contains a mandatory `status` flag evaluated dynamically on every authenticated request by the Edge Middleware (`auth.ts`).



3. End-to-End API Authorization Matrix

3.1 Authentication & Session Endpoints

Endpoint	Method	Required Auth	Allowed Roles	Permission Required	Resource Scope	ID Derivation Source	Audit Event Logged
/api/auth/login	POST	Optional	All	auth:login	Authentication	Request Body Credentials	LOGIN_SUCCESS, LOGIN_FAILURE
/api/auth/pin-login	POST	Optional	operator, supervisor	auth:pin	Quick Terminal Login	PIN Hash Verification	PIN_LOGIN_SUCCESS
/api/auth/logout	POST	Required	All	auth:logout	Active Session	JWT Header Session ID	LOGOUT
/api/auth/session	GET	Required	All	auth:session	Current Profile	JWT Validated User	None

3.2 User Management Endpoints

Endpoint	Method	Required Auth	Allowed Roles	Permission Required	Resource Scope	ID Derivation Source	Audit Event Logged
/api/users	GET	Required	admin, sysadmin	users:read	All User Profiles	Direct DB Query	None
/api/users	POST	Required	sysadmin	users:create	New User Creation	Server gen_random_uuid()	USER_CREATION
/api/users/[id]	GET	Required	admin, sysadmin, Self	users:read	Specific User Profile	Verified against JWT User	None
/api/users/[id]	PUT	Required	admin, sysadmin, Self	users:update	Profile Modifications	Verified against JWT User	USER_UPDATE
/api/users/[id]/status	PUT	Required	admin, sysadmin	users:status:update	Lock/Suspend Account	Server Invalidation	ACCOUNT_STATUS_CH
/api/users/[id]/role	PUT	Required	sysadmin	users:role:update	Change User Privilege	Server Invalidation	ROLE_CHANGE

3.3 Gate Scanning & Operations Endpoints

Endpoint	Method	Required Auth	Allowed Roles	Permission Required	Resource Scope	ID Derivation Source	Audit Event Logged
/api/gate/scan	POST	Required	operator, supervisor	gate:scan:create	Gate Entry/Exit Event	Derived from JWT Session	GATE_SCAN
/api/gate/logs	GET	Required	operator, supervisor, admin, sysadmin	gate:logs:read	Scan Event History	Assigned Gate Filter	None
/api/gate/logs/[id]/correction	PUT	Required	supervisor, admin, sysadmin	gate:logs:correct	Scan Error Override	Supervisor Session ID	SCAN_CORRECTION

3.4 Student Records & Gate Pass Endpoints

Endpoint	Method	Required Auth	Allowed Roles	Permission Required	Resource Scope	ID Derivation Source	Audit Event Logged
/api/students	GET	Required	admin, sysadmin, supervisor, warden	students:read	Student Directory	DB Authorization Filter	None
/api/students/[roll]	GET	Required	All Roles (Scoped)	students:read	Student Profile	Verification Check	None
/api/passes	GET	Required	admin, sysadmin, supervisor, student, parent	passes:read	Pass Requests	Student/Parent Relation	None
/api/passes	POST	Required	student, parent	passes:create	Request Pass	Derived Student ID	PASS_CREATED
/api/passes/[id]/approve	PUT	Required	admin, sysadmin, parent	passes:approve	Grant Exit Pass	Approver Session ID	PASS_APPROVED
/api/passes/[id]/reject	PUT	Required	admin, sysadmin, parent	passes:reject	Deny Exit Pass	Approver Session ID	PASS_REJECTED

4. Client-Controlled vs. Server-Derived ID Enforcement Rules

To prevent **Insecure Direct Object Reference (IDOR)** and **Identity Forgery** vulnerabilities, the system enforces the following explicit parameter derivation rules:

1. **Operator Identity:** Under NO circumstances is `operator_id` accepted from the client POST body in `/api/gate/scan`. The server strictly extracts `operator_id` from the verified JWT payload (`req.user.id`).

2. **Student Gate Pass Ownership:** When a student requests a pass, `student_id` is extracted from the authenticated user record bound to that student account.

3. **Parent Authorization:** Parents can only view or approve passes where `students.parent_id` matches the parent's authenticated `user.id`.

4. **Supervisor Gate Scope:** Supervisors are strictly restricted to reading logs and alerts for gate IDs included in their `users.supervised_gates` array.

5. Automatic Session Revocation Policies

The platform enforces dynamic session invalidation via database triggers and background workers:

- **Role Modification:** Updating a user's role in `users` instantly fires `trigger_notify_session_invalidation`, sending a `pg_notify` payload to invalidate all active JWT session records in `sessions`.
- **Status Change:** Transitioning an account from `ACTIVE` to `LOCKED`, `SUSPENDED`, or `DISABLED` automatically sets `sessions.active = FALSE` and populates `invalidated_at = NOW()`.
- **Password / PIN Reset:** Changing credentials immediately revokes all prior active sessions.